POS security and controls

The detailed action/receipt threat review, exact changed files and test scope are in security review. Financial service boundaries and database evidence are in services review. This document joins those reviews without turning source inspection into certification.

Trust and authority

The cashier browser is an untrusted input source. Actions derive actor and organization from authenticated permission context. Services validate tenant/location/terminal/session/cart relationships, module admission and authoritative totals. UI previews and client payment references do not establish stock, payment or ledger truth.

The authenticated permission resource identifier is audit context; it is not a newly introduced per-location assignment policy. Existing role aliases, read observe-mode rollout and enforced write admission were preserved. No roles, permissions, authentication factors or module entitlements were widened for testing. Refund/void and consequential token/offline operations retain their applicable fresh-authentication requirements.

Abuse cases and evidence

Attempt	Required boundary / observed protection	Evidence and limits
Read another tenant's sale, drawer or receipt	Trusted action scope, scoped service lookup, scoped client keys and authenticated result envelope	Action denials, drawer cache transition tests, public token binding and database cross-tenant cases. Not a complete penetration test of every unrelated endpoint.
Replace client actor, total, unit price, tax or provider reference	Schema plus server-owned catalog/cart revision/tender math/provider authority	POS service/action regression suites. No new rates or tax policy introduced.
Submit twice or retry an uncertain request under a new identity	Durable request payload/hash/revision and one authoritative result	Registry constraints and lifecycle tests; NOT_FOUND remains uncertain. Original identity is retained for retry.
Use a stale tab, expired ownership or late response	Browser lock and server lease; client generation/version fences and conservative expiry	Four red-to-green hook races plus real database competing-owner cases. Web Locks absence fails explicitly.
Read cached finance data after switching actor/tenant or losing permission	Scoped keys, server scope match, explicit denied render and guarded refetch	Drawer read regressions. A denied page is not a grant to obtain broader test access.
Correct a cash sale through an unrelated drawer or race its balance	Unique shift opening evidence, current linked terminal, sufficient funds and conditional balance update	Real PostgreSQL refund/void drawer and rollback cases.
Claim an electronic reversal without provider evidence	Explicit unsupported-rail guard before mutations	Service regression cases. No provider adapter was invented or enabled.
Hide a committed result behind receipt/cache/log failure	Durable result survives completion hydration; safe cache helper isolates after-commit faults	Financial completion and action logging/cache regressions.

Attempt	Required boundary / observed protection	Evidence and limits
Obtain a receipt using a guessed/expired/revoked/unregistered token	Signed sale/org/JTI binding, registry hash/status/expiry, scoped lookup	Token, registry, public service and page tests. Production secret provisioning remains external.
Extract customer/staff details or provider diagnostics from public HTML	Server-rendered field allowlist; only translated print label enters client component; public diagnostic redaction	Private-field exclusion, HTML escaping and public-versus-private diagnostic tests. A valid bearer still grants the receipt's intended data.
Leak bearer URL through audit, referrer or cache	New audit path is token-free; no-store/no-referrer/noindex on page/API/middleware	Audit and response-header tests. Historical audit/backups and infrastructure request logs require separate operator review.
Close while writes or uncertain offline/recovery work remain	Transactional session/terminal claims, pending-work barriers and closed-shift retirement	Seven PostgreSQL close tests and lifecycle races; statutory and hardware outcomes are not inferred.

Evidence, privacy and approvals

Receipt viewing may record token-access evidence but cannot submit a sale. Receipt checks and public page rendering do not invoke a charge, refund, stock mutation or ledger posting. Public display distinguishes purchase summary, pending fiscal work and recorded certification; no legal certification is inferred from a successful receipt render.

Cashier job titles do not grant capabilities. A finance or supervisor user must hold the operation's existing explicit permission, and approval requirements remain domain-specific. No general “administrator override” or unlock bypass was introduced. Terminal configuration retains the current `pos.session.start` policy; a dedicated configuration permission requires a coordinated role-design decision, not an incidental UI change.

The source manifest and command logs identify this dirty working tree. Test fixtures use a named disposable local database, synthetic data and documented simulations. No production data cleanup, historical audit rewriting, token rotation, provider call, live charge/refund/void or production deployment occurred.

The user separately authorized the exact posting-cycle migration on local application database `stoquify_replay_next_20260830`. Its completed result verifies the original SQL checksum, intended schema changes, matching Prisma history and preservation of unrelated schema/history. This narrowly scoped schema/history operation did not perform a sale or expand access. The accountant's French drawer rendering, location filtering, keyboard period selection and session expansion were observed through the existing finance permission; the POS denial remained in force while the authorized-account handoff was outstanding. The browser follow-up also records the null-closing-balance display correction without any financial mutation.

Release conditions: historical bearer remediation, authentic governance approvals, production receipt secret, distributed abuse/log review, remaining authorized browser and final-source build coverage, and applicable country/provider/hardware evidence. Twenty-one real PostgreSQL cases passed within their documented synthetic scope. See findings register and rollout/support. These controls reduce specific tested risks; they are not a claim of absolute security or statutory compliance.